

Cyber Security and Laws Notes

Q1. Explain Cyber crime & its classification.

- The crime that involves and uses computer devices and internet is known as cybercrime.
- Cyber crime can be committed against an individual or group or government and private organization.
- Cyber crime can cause direct harm & indirect harm to whoever.

Classification of cyber crime :

- a) Cyber crime against individual
- b) Cyber crime against property
- c) Cyber crime against org.
- d) Cyber crime against society
- e) Cyber emanating from use net newsgroup.

a) Cyber crime against individual :

- Electronic mail spoofing & other online frauds :
A spoofed mail means pretending to come from authorized source but actually it has been sent from an unauthorized source.
- Phishing :
Attempt to steal personal information from someone's computer by sending email that appears to come from some standard famous site.
- Spamming :
Act of sending bulk messages continuously.

b) Cyber crime against property :

- Credit card fraud
- Intellectual property crimes
- Internet time theft

c) Cyber crime against organization :

- Unauthorized accessing of computer
- Password sniffing
- Dos attack

d) Cyber crime against society

- Forgery
- Cyber terrorism
- Web jacking

e) Crime emanating from use net newsgroup :

- Usenet is newsgroup used for posting news, information by many user in different location.
- This use net can also be offensive, since inappropriate harmful messages can be posted.

Q2. Explain Cyber crime & IT act 2000.

- Indian government & different security agencies think that taking right decision right time is very important for solving cyber crime & related issues.
- The government of India passed the information technology Act 2000 along with legal notice on Oct. 17, 2000.
- In information technology act 2000, two more sections one added section 69 A, 69 B to strengthen the IT Act 2000.
- Section 69 is provision made to handle issues like interception, monitoring, decryption of information of a y computer.
- Section 69A and 69B is provision made to handle issues like blocking public web sites, monitoring and collecting network traffic from any computer resources.
- With rapid increase in use of internet cybercrime was also increasing, with new things like child pornography, publishing sexually explicit content.
- To avoid these crimes Indian government with permission of presidents of India in Feb 2009 IT amendment Act 2008 has passed.

Q3. Explain Objectives & features of It Act 2000.

Objectives:

1. Legal recognition of electronic records :
Provide validity & recognition to electronic records and digital signatures.
2. Cybercrime prevention :
Define and address offenses related to unauthorized access, data breaches, computer system tampering.
3. Data protection & privacy :
Establish provisions for protection of sensitive personal data and information.
4. Regulation of certifying authorities :
Define the role and responsibilities of certifying authorities responsible for issuing digital certificates.

Features:

1. Digital certificates & signature :
The IT act recognizes digital signature as legally valid and provides framework for use of digital certificates.
2. Offenses and penalties :
Defines various offenses related to unauthorized access, data breaches, cybercrime.
3. Data protection & privacy :
Outlines provisions for protection of sensitive personal data and information.
4. Network service provider's liability :
Defines the liability of network service providers for content hosted on their platforms.

Q4. Explain Cybercrime and Indian ITA 2000.

1. Indian government and different security agencies think that taking right decision at right time is very important for solving cybercrime and related issues or cases.
2. The government of Indian passed the information technology Act 2000 along with legal notice on Oct 17, 2000.

3. In information technology act 2000, two more sections are added section 69, 69A, 69B to strengthen the IT Act 2000.
4. Section 69 is provision made to handle issues like interception, monitoring or decryption of information of any computer.
5. Section 69A and 69B is provision made to handle issues like blocking public web sites, monitoring and collecting network traffic from any computer resources.
6. With the rapid increase in the use of internet cyber crime was also increasing with new things like child pornography, publishing sexually explicit content.
7. To avoid these crimes Indian government with permission of presidents of India in February 2009. It amendment Act 2008 was passed.

Q5. How criminals plan the attack?

- Criminals use methods & tools to locate the vulnerabilities of their target.
- Criminals plan active & passive attacks.
- Passive attacks attempt to gain information about target.
- Active attacks are used to compromise the system.

Phases:

- a. Reconnaissance (info gathering)
 - b. Scanning & identifying existing vulnerabilities
 - c. Launching attack.
- a. Reconnaissance :
 - Reconnaissance is nothing but information gathering.
 - In world of hacking, reconnaissance begins with “foot printing”.
 - Foot printing gives an overview about system vulnerabilities and provides judgment about exploitation of those vulnerabilities.
 - b. Passive attacks :
 - Passive attack involves gathering information about target without his/her knowledge.
 - Google or yahoo search.
 - Social media platforms likes fb, insta, linked in
 - Organizations website.
 - c. Active attacks :
 - Active attacks involves probing network to discover individual hosts to confirm information gathered in passive attack.
 - d. Scanning :

Scanning is key step to examine target.

 - i. Port scanning: Identify open/close ports.
 - ii. N/w scanning: Understand computer n/w systems like IP address, mac address.
 - iii. Vulnerability scanning: Understand existing weakness in system.
 - e. Attack :

This phase consist of gaining & maintaining the access.

 - i. Crack password
 - ii. Exploit password
 - iii. Execute malicious command
 - iv. Hide files
 - v. Cover tracks

Q6. Explain Credit card fraud in mobile & wireless computing era.

- Credit card fraud is form of identity theft that involves an unauthorized taking of another's credit information for purpose of charging purchases or removing funds from it.
- Elements of credit card fraud :
 - i. A person fraudulently obtains, takes, uses, sells, buys someone else's credit or debit card information.
 - ii. A person uses his or her own card with knowledge that it is expired or account lacks enough money to pay.
 - iii. Sell goods or services to someone else with knowledge that credit or debit card being used was illegally obtained.
- Types of credit card fraud :
 - i. Lost or stolen cards : common
Should reported immediately
 - ii. Account takeover
 - iii. Fraudulent application
 - iv. Clone
 - v. Never received
- How to protect :
Don't give your account number to anyone on phone.

Q7. Explain various types of credit card frauds.

- a. Card skimming :
 - Desc : Criminal use skimming devices to capture data from magnetic strip on credit or debit cards.
 - Prevention: Regularly inspect card readers for any unusual devices, over keypad while entering PIN.
- b. Account takeover :
 - Desc : Criminals gain unauthorized access to user's online account, by obtaining login credentials through phishing or other ways. Once in control, they can make unauthorized transactions using linked credit card.
 - Prevention: Use strong, unique passwords, enable multi-factor authentication.
- c. Phishing :
 - Desc : Fraudsters use deceptive emails, messages or websites to trick individuals to provide their credit card information.
 - Prevention: Avoid clicking on suspicious link, verify authenticity of websites.
- d. Lost or stolen card fraud :
 - Desc : Criminals use lost or stolen credit to make unauthorized transaction before cardholder reports the loss.
 - Prevention: Report lost or stolen cards immediately, regularly monitor card statements.
- e. Application fraud :
 - Desc : Criminals apply for credit cards using stolen identities or false information, once approved, they use credit cards for fraudulent transactions.
 - Prevention: regularly monitor credit reports, use identity theft services.

Q8. Explain different attack vectors in cyber security.

1. Phishing :
 - Desc : Phishing involves tricking individuals into disclosing sensitive information by posing as trust worthy entity through email, website, messages.
 - Example: email phishing, spear phishing, vishing, SMI
 - shing, whaling.
2. Malware attacks :
 - Desc : Malicious software is designed to disrupt, damage or gain unauthorized access to computer systems. Malware can be delivered through various ways such as infected email attachment or compromised website.
 - Examples : Viruses, worms, Trojan horses, spyware,
3. Man-in-the-middle attack :
 - Desc : In MTIM attack, an attacker intercepts & alters communication between two parties without their knowledge.
 - Example: Wi-Fi eavesdropping, session hijacking, DNS spoofing.
4. Denial-of service, DDos :
 - Desc : Dos attacks overwhelm a system, network, service with excessive volume of traffic, rendering it inaccessible. DDos attack involves multiple compromised systems to launch Dos attack.
 - Example: SYN/ACK attacks, DNS, BOTNET.
5. SQL injection :
 - Desc : SQL injection involves injecting malicious SQL code into database query to manipulate or gain unauthorized access to database.
 - Mitigation :
 - i. Use parameterized queries, input validation.
 - ii. Carry your card separately from your wallet.
 - iii. During transaction, keep eye on your card.
 - iv. Never sign black receipt.
 - v. Report to bank in any suspicious situation or your card gets stolen.

Q9. Explain Security challenges posed by mobile devices.

- Physical security :
 - i. Every year thousands of mobile phones are lost and mostly all who found that lost device tried to access information on phone.
- Secure data storage :
 - i. Mobile phones need good file encrypting for strong security.
 - ii. Without proper encryption, your personal docs, passwords of bank, credit card, etc. are on high risk.
- Malware on rise :
 - i. As in case with computers, malware is also damaging mobile phones.
 - ii. This is one of the unknown risk which can cause heavy losses.
- Bluetooth attacks :
 - i. As easy as Bluetooth is to use, it can be just as easy for attackers to gain access to someone's phone.
 - ii. It is important to turn off Bluetooth when not in use.
- Mobile browsing :
 - i. One of the best features of mobile devices is ability to browse web, but it also opens securing risks.

- ii. Problem is users can't see whole URL to verify whether link is safe, this can open up to attacks like phishing.

Q10. Explain Attacks on mobile devices.

Prime targets:

- i. Data
- ii. Identity
- iii. Availability

Attacks:

1. SMishing :

- SMishing uses SMS (short message service) to send fraud text messages or links.
- Criminals cheat users by calling, Victims may provide sensitive personal information such as credit card information, account info.

2. WEP attack:

- i. Wired equivalent privacy (WEP) is security protocol to provide wireless local area network (WLAN) same level of security as wired LAN.
- ii. WEP uses a key for encryption. Since no. of people sharing key, criminals have access to large amount of traffic.

3. Blue jacking:

- i. Blue jacking is used for sending unauthorized messages to another Bluetooth device.
- ii. Bluetooth is high speed but very short range wireless technology for exchanging data between desktop & mobile.

4. Replay attacks:

- i. In replay attack an attacker spies on information being sent between sender & receiver.
- ii. Attacker can intercept & retransmit information to cause delay in data transmission.

5. Bluesnarfing :

- i. It occurs when attackers copy victim's information from his device.
- ii. An attacker can access information such as user's calendar, contact list, email, text without leaving evidence.

Q11. Explain Illegal activities in cyber café? Also explain Security & safety measures.

a. Unauthorized access :

Attempting to access someone else's accounts or data without permission.
Unauthorized access to computer systems, networks, databases.

b. Malware distribution :

Downloading or distributing malicious software, viruses or other forms of malware.

c. Cyber theft :

Engaging in identity theft or stealing sensitive information

d. Cyberbullying :

Harassing or threatening others online.

e. Illegal downloads :

Downloading copyrighted materials without proper authorization.

- f. Fraudulent activities :
Engaging in online scams or fraudulent schemes.

Safety & security measures:

- a. Uses a secure connection :
Make sure cyber has secure & private Wi-Fi to protect from authorized access.
- b. Avoid saving passwords :
Don't save password
- c. Logout properly
- d. Update security software
- e. Use HTTPS
- f. Be cautious with personal information (stay with computer)
- g. Check for surveillance transactions.
- h. Avoid online financial transactions.
- i. Clear history & files
- j. Virtual keyword

Q12. What are Botnets? How it is exploited by attacker to cause cyber attack

- A botnet is network of compromised computers, referred to as 'bots' 'or' 'zombies' that are controlled by single entities known as botmaster.
- These compromised computers, which may include desktops, laptops, servers, IOT devices, which are infected with malicious software that allows attacker to remotely control them.
- Botnets are commonly used by attackers for various malicious activities, including cyber-attacks.

Characteristics:

- i. Compromised devices
- ii. Command & control infrastructure
- iii. Distributed nature
- iv. Persistence
- v. Versatility

Exploitation by attacker:-

- i) DDOS attack :
Botnets are often used to launch powerful DDOS attacks, overwhelming targets servers or network infrastructure with flood of traffic.
- ii) Spam and phishing campaigns :
Botnets are utilized to send massive volumes of spam email or phishing messages.
- iii) Credential stuffing :
Botnet can automate process of trying large number of usernames & password combinations to gain unauthorized access.
- iv) Information theft :
Some botnets are designed to steal sensitive information such as login credentials, financial data or personal information.

Litigation strategies:

- a. Security software
- b. Network monitoring
- c. Firewall & IPS

- d. User education

Q13. Explain Vishing.

Vishing short for “voice phishing”.

It is type of social engineering attack where attackers use phone calls to trick individual into revealing sensitive information or performing certain actions.

Vishing involve impersonating such as banks, government agencies, tech support to gain trust of target.

Working:

- a. Call impersonation: Attackers pose as representative of trusted organizations, such as banks, government agencies, tech support.
- b. Creating urgency: Vishing call create sense of urgency or fear to prompt immediate action.
- c. Request for sensitive information: Caller asks target to provide sensitive information such as passwords, security no, OTP, credit card details, or other personal information.
- d. Manipulating caller ID: Attackers may manipulate caller ID information to make it look like it is coming from legitimate source.
- e. Using threats: Vishing attack may use threats to coerce target into complying with their demands.

How to protect:

- i. Verify caller identity
- ii. Do not share personal information
- iii. Use two factor authentication: (extra layer of security)
- iv. Educate yourself : (awareness)
- v. Keep software updated (security s/w, phone O S)
- vi. Use call blocking apps
- vii. Trust your instincts

Q14. Explain methods of password cracking.

- a. Brute force :
 - Description: In brute force attack, an attacker systematically tries every possible combination of characters until the correct password is found.
 - Techniques: Exhaustive search, trying all combinations of letters, numbers, symbols.
 - Mitigation: Implement account lockout policies, use strong passwords.
- b. Dictionary attacks :
 - Desc : Dictionary attack involve using precompiled lists of common passwords, word, phrases to attempt to match against passwords.
 - Techniques: Using wordlists, dictionaries, and common password dbs.
 - Mitigation: Encourage users to use unique & complex passwords.
- c. Rainbow table attack :
 - Desc : Rainbow table attack use precomputed tables that map hash values of passwords to their plain text equivalents.
 - Techniques: comparing password hash values against entries in rainbow table.

- Mitigation: Use strong cryptographic hashing algorithms implement salted hashes.
- d. Phishing attacks :
 - Desc : Phishing attacks involve tricking users to reveal their passwords by posing as trustworthy entity, through emails, websites or msgs.
 - Techniques: Spoofing websites, take login pages.
 - Mitigation: Educate user about phishing sites, use email filtering solutions.
- e. Shoulder surfing :
 - Desc : In shoulder surfing, attackers visually observe user entering their shoulder or by other means.
 - Techniques: Observing keystrokes, video recording.
 - Mitigation: Use privacy screens, encourage users to be aware of the surrounding while entering password.

Q15. Difference between Virus vs worms.

	parameters	Worms	virus
1	Def ⁿ	A worm is form of malware that replicates itself & can spread to different computers via network.	A virus is malicious executable code attached to another file which can be harmless.
2.	Host	Doesn't need host to replicate from one computer to another.	Need host to spreading.
3	Harmful	Less harmful.	More harmful.
4.	Execution	Worms one executed via weaknesses in system.	Viruses are executed via executable files.
5.	Types	Internet worms, email worms, file shaming worms, messaging worms.	Boot sector virus, direct action virus, macro virus.
6.	Ex.	Morris worm, storm worm, etc.	Creeper, blaster, slammer, etc.
7.	Speed	Spreading speed is faster	Spreading speed is slow.
8.	Comes from	Generally comes from downloaded files through n/w.	Generally come from shared files.

Q16. Explain Steganography.

- Steganography is technique used in cybersecurity to conceal information within other non-secret data in way that does not raise suspicion.
- Unlike on cryptography, which makes data unreadable to unauthorized users, steganography is concerned with hiding existence of information.
- Goal: Goal is to hide secret data in innocent looking file such as images, audio files, video files, text, etc.
- Risk: Steganography can be used for both legitimate & malicious purpose. While applications in digital rights management & data authentication, cybercriminals may use it to hide malware, exfiltrate data.
- Types: 1. Image 2. Audio 3. Video 4. Text
- Tools: 1. Stegano 2. Open stego 3. Quick stego
- Use cases: 1. Law enforcement 2. Digital rights management (DRM)
- 3. Communication security.
- Detection tools: 1. Zsteg 2. Stegextract 3. Stegoveritas.

Q17. Explain DOS & DDOS in detail.

- A denial-of-service (DOS) and its advanced form, the distributed denial of service (DDOS) are malicious attempt to disrupt normal functioning of targeted server, service or network.
- Primary goal is to overwhelm target with flood of traffic or requests, to make it unavailable to users.

DOS:

- A DOS attack is cyber-attack that aims to disrupt or disable a single system or network by flooding it with excessive traffic.
- Attack mechanisms :
 - i. Traffic overload
 - ii. Resource depletion
- Types of DOS :
 - i. TCP SYN flooding
 - ii. UDP flooding
 - iii. Ping flood
 - iv. http flooding
- Mitigation techniques :
 - i. Traffic filtering : filter malicious traffic
 - ii. Rate limiting : to control no. of requests
 - iii. Firewalls & IPS : to block attack patterns

DDOS:

- DDOS attack is an evolved form of DOS where multiple compromised computers are coordinated to flood target.
- Attack mechanisms :
 - i. Botnets
 - ii. Amplification attacks
 - iii. Reflection attacks
- Types of DDOS attacks:
 - i. TCP/IP protocol exploits
 - ii. Application layer attacks
 - iii. Volumetric attacks
- Mitigation techniques :
 - i. Content delivery network : distributing content to absorb & mitigate DDOS
 - ii. Traffic scrubbing services : analyze & filter out malicious traffic before target
 - iii. Rate limiting : to control no of requests

Q18. Explain different buffer overflow attacks & mitigation.

- Buffer overflow attacks are type of security vulnerability in software that occurs when a program writes more data to block of memory, or buffer, than it was allocated to hold.
- Buffer overflow vulnerabilities are commonly exploited by attackers to gain unauthorized access to systems.
- a. Stack based buffer overflow :
 - Desc : Occurs when data overflows from a buffer on the call stack into adjacent memory regions.

- Mitigation: Use stack canaries, which are values placed between local variables and control data on stack to detect buffer overflows.
- b. Heap based buffer overflow :
 - Desc : Involves overflowing buffers allocated on the heap potentially leading to corruption of dynamically allocated memory structures.
 - Mitigation: Implement secure memory allocation functions, use modern memory management techniques.
- c. Mitigating buffer overflow :
 - Input validation & bounds checking :
 - i. Ensure that data is properly validated & sanitized
 - ii. Implement bounds checking to ensure that data written to buffers does not exceed allocated space.
 - Use safe programming practices :
 - i. Follow secure coding standards & best practices
 - ii. Use safer alternatives to vulnerable functions
 - Address space layout randomization (ASLR) :
Randomize memory layout to make it more difficult for attackers to predict the location of specific code or data.
 - Compiler security features :
 - i. Utilize compiler-specific security features, such as protection options.
 - ii. Enable warning for potentially unsafe code constructs.
 - Regular software updates :
 - i. Keep software and systems up-to-date with latest security patches.
 - ii. Apply updates & patches provided software vendors.

Q19. Explain E-commerce & types.

- Electronic commerce or e-commerce is a business model that let firms & individuals buy & sell things over internet.
- It refers to commercial transactions which are conducted online.
- E-commerce can be drawn on many technologies such as mobile commerce, internet marketing, online transaction processing, electronic funds transfer, supply chain management, electronic data interchange (EDI), inventory management systems.
- E-commerce has helped business establish a wider market present by providing cheaper & more efficient distribution channels for their products.

Types:

- a. Business to business (B2B) :
 - i. Refers to all electronic transaction of goods & sales that are conducted between two companies, generally between producers & wholesalers.
 - ii. Ex. India mart.
- b. Business to consumer (B2C) :
 - i. E-commerce where customer gets big market to purchase good & services.
 - ii. Ex. Amazon, Flipkart, Myntra.
- c. Consumers to consumer (C2C) :
 - i. This model uses online platform of money & social media platforms for existence.
 - ii. Ex. OLX, eBay.
- d. Consumer to business (C2B) :

- i. Customer provides goods or services in exchange for money.
 - ii. Ex. Advertisement of company by an influencer amongst his followers, etc.
- e. Business to administration (B2A) :
 - i. Refers to services & products offered by companies to public administration.
 - ii. Ex. Small Company providing IT support to administrative.
- f. Consumer to administration (C2A) :
 - i. This includes all transaction where there is payment made electronically towards public administration.
 - ii. Ex. Taxes, health appointment.

Q20. Explain Intellectual property.

- Intellectual property rights are legal rights that cover the privileges given to individuals who are the owners and inventors of work & have created something with their intellectual creativity.
- Individual related to areas such as literature, music, invention, etc.
- The creator/inventor gets exclusive rights against any misuse or use of work without his/her information.

Types:

- Copyright :
Copyright protects original works of authorship, including literary, artistic & digital creations.
- Trademarks :
Trademarks protect symbols, names & slogans used to identify goods or services, indicating their source.
- Patents :
Patents protect inventions & discoveries, providing exclusive rights for limited period.
- Trade secrets :
Trade secrets protect confidential business information, such as formulas, processes & strategies that provide competitive advantages.
- Digital rights management (DRM) :
DRM technologies are used to control access to digital content & protect it from unauthorized use.

Q21. Explain evidence aspect in cyber law.

- Evidence is information that tends to prove or disprove a fact in question.
- Evidence may consist of documents, public records, affidavits, etc. it also can be an object, such as murder weapon, anyone's existence.
- There are types of evidence
 - i. Direct
 - ii. Circumstantial
- Direct evidence tends to prove fact without help of other evidence. Ex. An eyewitness to murder gives direct evidence by saying that he/she saw accused kill victim.
- Circumstantial evidence tends to prove fact that support main fact in question. Ex, witness give circumstantial evidence by saying that he or she saw accused leave murder scene. This indicates that accused could have killed victim, but it doesn't directly prove it.
- i) Section 17 : admission defined

- ii) Section 22A: when oral admission as to contents of electronic record Relevant
- iii) Section 59: proof of fact by oral evidence
- iv) Section 67A: proof as to digital signature
- v) Section 73A: proof as to verification of digital signature
- vi) Section 85A: presumption as to electronic agreements.

Q22. Explain Global trends in cyber law.

- a. Stringent regulatory rules are put in place by many countries to prevent unauthorized access to networks, such rules are called as penal offences.
- b. Stakeholders of mobile companies will call upon governments to regulate emerging mobile threats & crimes.
- c. The growing awareness on privacy is another upcoming trend.
- d. Cloud computing is another major upcoming trend. With more advanced technologies, huge amount of data flow in cloud which can be open for cyber-attacks.
- e. The growth of bit coins & other virtual currency is yet another trend. It can increase in further.
- Some other :
 - i. AI
 - ii. Metaverse
 - iii. FOT
 - iv. Ransom ware
 - v. Dark net

Q23. Explain IT act 2008 & its amendment.

- It act 2008 has come to effect from 7 oct 2009. This act received both bad & good responses.
- Special sections like section 69 which provides power to Indian government for interception, monitoring, decryption & blocking electronic data.
- Under the Indian It act 2008 digital signature was considered only valid signature. For purpose of any kind of business transactions in India.
- Government of India decided under IT act 2008 to introduce concept of electronic signature for purpose of information technology, cyber laws, and business transactions.
- The new It act lacks coverage of areas like social networking, user generated content, spyware, malware.

Amendments:

- Section 43A & 72A of information act provides protection to data in India. If we want to transfer data outside India one cannot seek protection under these sections.
- Cyber security in India is not up to mark and India has no cyber security policy & strategy the can be implemented under any legal framework.
- India having only two It acts, It act 2000, It act2008. Because of insufficient laws India has faced many cyber-attacks in past & in present also.

Q24. Explain Legal framework for electronic data interchange.

- EDI (electronic data interchange) can be defined as exchange of documents in standardized electronic form.

- The type of documents exchange by EDI includes business transactions such as orders, invoices and payment instructions.
- There are 2 key elements in EDI
 - a. Electronic documents replace their paper counterparts.
 - b. Exchange of documents takes place in standardized format.
- In a typical EDI application to support purchasing, an EDI system is integrated with existing purchase system at customer side.
- EDI can also be defined as computer-to-computer exchange of structured data.
- Electronic data interchange scenario in India :
 - a. EDI council in India.
 - b. India EDI FACT committee
 - c. Working group
 - d. Education and awareness
 - e. VAN service providers
 - f. EDI implementation in government regulatory agencies.

Q25. Explain SOX.

- SOX stands for Sarbanes-Oxley act
- The SOX was passed in 2002.
- The SOX act was passed to ensure that corporate executives are held responsible for establishing, evaluating & monitoring effectiveness of their financial reporting.
- SOX specifically focuses on accuracy of company's financial records & controls around these records related to income, expenses, accounting and so on.
- Network security is fundamental component of SOX compliance.
- SOX-key IT requirements :
 - a. Organization must have written security policy
 - b. Organization should baseline these current compliance state.
 - c. Organization must log and audit access to financial data.
- Main areas that act is focused on :
 - a. Increasing criminal punishment
 - b. Accounting regulation
 - c. New protections
 - d. Corporate responsibility
- Benefits :
 - a. Identifying & strengthening internal controls
 - b. Reliable, efficient audits
 - c. Processes primed for growth

Q26. Explain GLBA.

- GLBA stands for Gramm-Leach-Bliley act
- GLBA was passed in 1999 & US president bill Clinton signed GLBA.
- GLBA is also known as financial modernization act of 1999.
- GLBA includes standards to protect customer data from internal and external threats & unauthorized access.
- This level of security is mandatory to ensure that companies maintain data integrity & privacy for employees & customer that have provided PI.
- 3 key rules of GLBA :
 - a. Financial privacy rule

- b. Safeguards rule
- c. Pretexting provisions
- Key IT requirements :
 - a. Orgs must have written security policy
 - b. Orgs must establish risk assessment-vulnerabilities scan
 - c. Orgs must monitor & report on files, folders, databases that contain customer financial information.
 - d. Orgs must notify consumer if their information is compromised.

Q27. Explain HIPAA.

- HIPAA stands for health insurance portability & accountability act.
- HIPAA is U.S. federal law that was enacted in 1996 to protect individual's health information and ensure privacy and security of electronic health records.
- The primary goals of HIPAA includes safeguarding individual's health information facilitating electronic exchange of healthcare data.

Key components:

- a. Privacy rule :
The HIPAA privacy rule sets standards for protecting individual's medical records & other personal health information.
- b. Security rule :
 - The HIPAA security rule establishes standards for the security of electronic protected health information (ePHI)
 - It includes to protect confidentiality, integrity, availability of ePHI.
- c. Transactions & code set rule :
Transactions & code set rule standardizes electronic exchange of healthcare transactions.
- d. Unique identifiers rule :
Unique identifiers rule establishes standard identifiers for healthcare providers, health plants and employers.
- e. Enforcement rule :
The HIPAA enforcement rule outlines the procedures and penalties for violations of HIPAA rules.

Common HIPAA violations:

- a. Stolen phn/laptop
- b. Stolen USB drive
- c. Malware incident
- d. Ransomware attack
- e. Hacking
- f. Sending PHI to wrong contact
- g. Office break-in
- h. Social media posts

Q28. Difference Cybercrime vs cyber fraud.

	Cybercrime	Cyber fraud
Defn	Cybercrime refers to any criminal activity that involves computer or computer network as target, tool or medium of crime.	Cyber fraud especially refers to fraudulent activities that are conducted through digital means with primary intention of financial gain or deception.
Scope	Cybercrime is broad term encompassing various illegal activities like hacking, malware distribution, identity theft, online harassment.	Cyber fraud focuses on deceptive practices aimed at obtaining money, sensitive information, or valuables from individuals or organizations.
Intent	The intent behind cybercrime may not be financial gain.	The primary intent behind cyber fraud is financial gain.
Ex.	Unauthorized access to computer, spreading malware, denial-of-service.	Phishing attacks, online scans, credit card fraud.

Q29. Explain various threats associated with cloud computing.

- a. Data breaches :
 - Unauthorized access to sensitive data stored in cloud can lead to data breaches.
 - Implement strong access controls, encryption and monitor access to sensitive data.
- b. Insecure interfaces and APIS :
 - Description: Weaknesses in cloud service interfaces and application programming interfaces can be exploited by attackers to gain unauthorized access.
 - Mitigation: Regularly access and secure interfaces and APIs, use strong authentication.
- c. Data loss :
 - Description: Data loss can occur due to accidental deletion, corruption or malicious activities.
 - Mitigation: Implement robust data backup and recovery mechanisms.
- d. Insufficient security architecture :
 - Decs : Poorly designed security architecture in cloud environments can lead to vulnerabilities and weaknesses.
 - Mitigation: Adopt a well-defined and secure architecture and follow best security practices.
- e. Insecure storage services :
 - Desc : Weak security configurations of storage services can lead to unauthorized access to stored data.
 - Mitigation: Encrypt data at rest, regularly monitor storage configurations.

Q30. Explain security risks for organisations.

- a. Cyber security threat :
 - Malware : malicious s/w such as virus, Trojan
 - Phishing : social engineering attack
 - DOS : overwhelm network
- b. Insider threat :

- Employee negligence: unintentional actions by employees, such as clicking malicious link.
- Insider malice: Deliberate actions by employees or trusted individuals to steal data, introduce malware, harm, org.
- c. Data breaches :
 - Unauthorized access to sensitive data, whether through cyber-attacks, social engineering, leading to exposure of confidential information.
- d. Weak authentication & access controls :
 - Inadequate password policies, weak authentication method insufficient access control can lead to unauthorized access to system and data.
- e. Unpatched software & systems :
 - Failure to apply security patches & updates, leaves system vulnerable to know exploits.

Q31. Explain E-contracts & types.

- E-contracts or electronic contracts are agreements entered into and executed in digital form without need for physical signature or paper documents.
- These contracts are created, communicated & stored electronically.
- E-contracts become increasingly common with widespread use of internet & digital technologies.

Types:

- a. Click wrap contracts :
 - Click wrap contracts are common in online transaction.
 - User agrees to terms & conditions on clicking “I agree” or similar button.
- b. Browsewrap contracts :
 - In browsewrap contracts, terms and conditions are posted on website and users are bound by them by simply using or accessing website.
- c. Email agreements :
 - Email agreements are contracts formed through email exchanges.
 - Even through email communication lack formal signature, it can still constitute legally binding agreement.
- d. E-signature :
 - E-sign involve using electronic signature to sign contracts.
- e. Social media contracts :
 - Social media platforms may have terms of service or user agreements that users agree to when creating account.